RocketBase

SOFTWARE-CHECK · PRÜFBERICHT

Musterbericht

So sieht der Bericht aus, den ihr nach einem Software-Check in der Hand habt.

Betrieb	Beispielbetrieb GmbH (fiktiv)
Geprüft	Auftragsportal für Kunden und internes Planungstool, beide zum großen Teil mit KI gebaut
Rahmen	Kapitel des OWASP ASVS 5.0, Level 2
Umfang	Quellcode, Infrastrukturvorlagen, laufende Testinstanz

Dies ist ein Muster, kein Bericht eines Kunden. Betrieb, Systeme und Befunde sind ausgedacht. Die Befunde sind so gewählt, wie sie bei mit KI gebauter Software typischerweise auftreten. Ein echter Bericht ist länger und führt alle Befunde einzeln auf.

INHALT

1 · Ergebnis in Kürze
2 · Befunde, Beispiel
3 · Was ausdrücklich so bleiben darf
4 · Reihenfolge
5 · Papier zum Betrieb, Auszug
6 · Grenzen der Prüfung

1 · Ergebnis in Kürze

Beide Systeme sind solide gebaut. Anmeldung, Umgang mit Zugangsdaten und Schutz gegen Einschleusung sind sauber umgesetzt. Die wichtigen Befunde liegen nicht dort, wo Angreifer von außen ansetzen, sondern bei gleichzeitigen Zugriffen, in der Produktionsumgebung und darin, ob ein Ausfall überhaupt bemerkt wird.

3 hoch
vor dem Go-live beheben

9 mittel
vor dem Go-live, wenig Aufwand

14 niedrig
nach und nach

0 von außen
Lücken mit Zugriff aus dem Internet

Abdeckung nach Kapiteln des OWASP ASVS 5.0

KAP.	THEMA	ERGEBNIS	KURZ
V1	Kodierung und Bereinigung	ohne Befund	durchgängig parametrisierte Abfragen
V2	Prüfung und Geschäftslogik	Schwerpunkt	gleichzeitige Zugriffe, Grenzwerte
V3	Sicherheit im Browser	einzelne	Sicherheitskopfzeilen fehlen
V4	APIs und Webservices	einzelne	Anfragebegrenzung nicht eingebunden
V5	Umgang mit Dateien	einzelne	Dateigröße beim Upload ungeprüft
V6	Anmeldung	ohne Befund	vollständig konfiguriert
V7	Sitzungen	einzelne	kein Abmelden nach Inaktivität
V8	Berechtigungen	einzelne	Rolle aus dem Token statt aus der Datenbank
V11	Kryptografie	ohne Befund	Schlüssel im Tresor
V12	Sichere Kommunikation	ohne Befund	nur verschlüsselt erreichbar
V13	Konfiguration	Schwerpunkt	Produktion wie Entwicklung eingestellt
V14	Datenschutz	einzelne	kein Löschkonzept
V15	Sicherer Code und Architektur	einzelne	veraltete Abhängigkeiten
V16	Protokollierung und Fehler	einzelne	keine Alarmierung, Zustandsmeldung immer „ok“

Nicht zutreffend und deshalb nicht geprüft: V9 Tokens im Eigenformat, V10 OAuth und OIDC, V17 WebRTC.

2 · Befunde, Beispiel

Drei von 26 Befunden. Jeder Befund folgt demselben Aufbau, damit ihr ihn ohne uns weitergeben könnt.

B-01 · Zwei Buchungen auf den letzten freien Termin werden beide angenommen

hoch

KAPITEL	V2 Geschäftslogik
FUNDSTELLE	`planung/buchung.ts, Zeilen 40–72`
BEOBACHTUNG	Die Anwendung liest den freien Platz, entscheidet im Speicher und schreibt danach, ohne Sperre. Kommen zwei Anfragen gleichzeitig, sehen beide den Platz als frei. Die nächtliche Bereinigung löscht die doppelte Buchung, aber keiner der beiden Kunden erfährt davon.
NACHWEIS	Integrationstest gegen eine echte Datenbank, im Termin vorgeführt: erwartet 1 angenommen und 1 abgelehnt, tatsächlich 2 angenommen.
ABGLEICH	Nicht im eigenen Backlog geführt.

AUFTRAG, DIREKT AN EURE KI

Setze in buchung.ts beim Lesen des Platzes eine Zeilensperre und schreibe in derselben Transaktion. Vorbild: die Reservierung in lager/reservierung.ts, Zeilen 18–35, die es bereits richtig macht. Danach muss der beiliegende Test grün sein.

B-04 · Die Zustandsmeldung sagt „ok“, auch wenn die Datenbank weg ist

hoch

KAPITEL	V16 Protokollierung und Fehler
FUNDSTELLE	`api/health.ts`
BEOBACHTUNG	Die Meldung prüft nur, ob der Server antwortet. Genau sie ist die erste Prüfung nach jeder Auslieferung. Eine Alarmierung gibt es nicht. Ein Ausfall fällt erst auf, wenn ein Kunde anruft.
NACHWEIS	Datenbank auf der Testinstanz gestoppt, Meldung abgerufen: `{"status":"ok"}`.

AUFTRAG, DIREKT AN EURE KI

Ergänze in health.ts eine Abfrage gegen die Datenbank mit kurzem Zeitlimit und gib bei Fehler den Status 503 zurück. Richte für diese Meldung einen Alarm per Mail und Telefon ein.

B-09 · Die Begrenzung der Anfragen ist installiert, aber nirgends eingebunden

mittel

KAPITEL	V4 APIs und Webservices
FUNDSTELLE	`package.json, server/app.ts`
BEOBACHTUNG	Das Paket ist eingetragen, wird aber an keiner Stelle verwendet. Anmeldung und Formulare lassen sich beliebig oft aufrufen.

AUFTRAG, DIREKT AN EURE KI

Binde die Begrenzung in app.ts für Anmeldung, Passwort-Rücksetzung und Kontaktformular ein, 10 Anfragen pro Minute und Adresse. Schreibe einen Test, der die 11. Anfrage ablehnt.

3 · Was ausdrücklich so bleiben darf

Diese Seite ist kein Lob, sondern Bestand. Sie hilft euch, wenn der nächste Berater kommt und alles neu bauen will.

- **Anmeldung.** Vollständig konfiguriert, ohne Hintertür. Ohne Konfiguration startet die Anwendung nicht.
- **Zugangsdaten.** Nichts im Quellcode, alles im Schlüsseltresor.
- **Schutz gegen Einschleusung.** Datenbank, Schnittstellen und Dateipfade durchgängig abgesichert.
- **Geldbeträge.** In ganzen Cent, ohne Fließkomma.
- **Entscheidungen.** Nummeriert, mit Datum und Begründung. Das macht die Prüfung erst möglich.

4 · Reihenfolge

Die Befunde, gebündelt zu Arbeitsschritten. Die Reihenfolge legen wir im Abschlusstermin gemeinsam fest.

SOFORT

3 Schritte

Was Geld oder Daten dauerhaft beschädigen kann: Sperren bei Buchung und Zahlung, Grenzwerte in der Datenbank.

VOR DEM GO-LIVE, WENIG AUFWAND

6 Schritte

Zustandsmeldung, Anfragebegrenzung, Rechte aus der Datenbank. Zusammen wenige Tage.

VOR DEM GO-LIVE, GRÖSSER

4 Schritte

Auslieferung mit Rückweg, Alarmierung, Produktionsumgebung härten, Tests gegen echte Datenbank.

DANACH

2 Schritte

Löschkonzept, Abmelden nach Inaktivität, regelmäßige Prüfung der Abhängigkeiten.

5 · Papier zum Betrieb, Auszug

Fragen, die man nicht im Code sieht, sondern erst im Betrieb. Sie entstehen meist im Abschlusstermin und werden danach eigens aufgeschrieben.

> **Mailweg**
>
> Was passiert, wenn eine Mail nicht zugestellt wird? Landet die Unzustellbarkeitsmeldung als scheinbare Kundenantwort am Vorgang? Ist die Absenderdomain so eingerichtet, dass große Anbieter die Mails annehmen?

> **Backup**
>
> Hat schon einmal jemand zurückgespielt? Ein vollständiger Rücksprung löscht alles, was seither erfasst wurde. Wer darf ein zweites Exemplar der Datenbank anlegen und gezielt daraus holen?

> **Alarmierung**
>
> Wer bekommt nachts um drei eine Nachricht, und was tut er dann?

> **Weg in die Produktion**
>
> Wie kommt eine neue Version live, und wie kommt sie zurück, wenn etwas schiefgeht?

6 · Grenzen der Prüfung

Kein Penetrationstest, kein Lasttest, kein Zertifikat. Geprüft wurden Quellcode und Infrastrukturvorlagen in zwei Durchgängen, einmal mit der Projektdokumentation und einmal bewusst ohne. Kommentare gelten dabei als Behauptung. Die Kapitel ohne Befund sind geprüft, nicht garantiert.

WAS ZUM SOFTWARE-CHECK GEHÖRT

Bericht wie dieser, zu jedem Befund Fundstelle und Auftrag für eure KI. Abschlusstermin von etwa anderthalb Stunden mit Live-Nachweisen. Papier zum Betrieb. Der Preis richtet sich nach dem Umfang des Codes und steht nach dem kostenlosen Erstgespräch fest.

Erstgespräch: rocketbase.io/software-check · marten@rocketbase.io · 04173 2199520